

Faculty of Business and Information Technology
MITS 5600G: Security Policies and Risk Management
Case Study Info – Group Assignment

Contents

Overview	1
Topic Selection and Group Formation	1
Assignment Deliverables	2
Part 1 – Group Presentation (10%)	2
Presentation Requirements	2
Required Discussion Component	2
Presentation Materials	3
Participation Requirement	3
Part 2 – Group Written Report (5%)	3
Part 3 – Individual Contribution Reflection (5%)	4
Academic Integrity	4
Grading Rubric	4
Case Study Topics	6

Overview

This assignment is designed to deepen students' understanding of security policies, governance, risk management, incident handling, and organizational security practices through the analysis of real-world cybersecurity incidents.

Students will work in groups of two to investigate, analyze, and present a major cybersecurity case study. The assignment is designed to move beyond simply describing an incident. Students are expected to conduct meaningful research, explain the technical and organizational aspects of the incident, evaluate the effectiveness of policies and controls, and provide recommendations grounded in cybersecurity best practices.

Topic Selection and Group Formation

Students will work in groups of two. In exceptional situations, and depending on enrollment, the instructor may approve individual groups or groups of three.

Groups and case study topic selection will take place during the first class.

Students who have not joined a group by the end of the first class will have until 5:00 PM the following day to join a group and select a topic. Students who fail to do so will be assigned to a group and a topic by the instructor.

Assignment Deliverables

The assignment consists of three components:

Component	Weight	Due
Group Presentation	10%	By 2:00 PM on the day of the presentation.
Group Written Report	5%	By 2:00 PM on the day of the presentation.
Individual Contribution Reflection	5%	By 2:00 PM on the day of the presentation.

Part 1 – Group Presentation (10%)

Each group will deliver a professional in-class presentation on their assigned case study.

Presentation Requirements

Duration:

- Presentation: approximately 12 - 15 minutes
- Class discussion and Q&A: approximately 10 minutes

Presentation Expectations:

The presentation should:

1. Explain the background of the organization and incident.
2. Describe the attack timeline and how the incident unfolded.
3. Explain the technical aspects of the attack.
4. Analyze organizational, governance, policy, or operational failures.
5. Evaluate the effectiveness of the organization's response.
6. Discuss legal, ethical, regulatory, and business implications.
7. Provide recommendations and lessons learned.
8. Connect the incident to concepts discussed in class when applicable.

Required Discussion Component

Each group must prepare at least five meaningful discussion questions for the class.

Discussion questions should:

- encourage analysis and debate,
- connect to cybersecurity policy and risk management concepts,
- and avoid simple yes/no answers.

The questions should be included in your slide deck and projected during the Q&A portion.

Groups are expected to actively facilitate class discussion.

Presentation Materials

Presentation slides (and all deliverables) must be uploaded to Canvas by 2:00 PM on the day of the presentation.

Students must upload:

1. PowerPoint presentation (.pptx or .pdf)
2. Written report (.pdf)
3. Individual contribution reflections (submitted individually)

Use the following file naming convention:

- GroupX_CaseStudyName_Presentation.pptx (e.g., Group7_Desjardins_Presentation.pptx)
- GroupX_CaseStudyName_Report.pdf
- LastName_FirstName_Reflection.pdf (individual submissions)

Presentation slides should:

- be readable and professional,
- avoid excessive text,
- include diagrams, visuals, timelines, or technical illustrations where appropriate,
- and properly cite sources.

Participation Requirement

All group members must:

- attend the presentation,
- actively participate,
- and be prepared to answer questions.

Each group member must speak for a roughly equal portion of the 12-15-minute presentation. A student who does not present will receive a grade of zero for the presentation component.

Part 2 – Group Written Report (5%)

Each group must submit a concise written report summarizing their case study analysis.

Length: 5–6 pages (title page, references, and appendices are **not** counted). Appendices should contain only supporting material, not core analysis.

Required Sections

The report must include:

1. Title Page
2. Executive Summary
3. Background of the Incident
4. Technical Analysis
5. Policy / Governance / Risk Analysis
6. Incident Response and Recovery
7. Lessons Learned and Recommendations
8. Conclusion
9. References

Part 3 – Individual Contribution Reflection (5%)

Each student must individually submit a one-page reflection describing their contributions to the case study.

The reflection must:

- Clearly describe the student’s specific contributions.
- Explain what research, writing, technical analysis, or presentation work was completed by the student.
- Describe the most important lesson learned from the case study.
- Reflect on how the incident relates to cybersecurity governance, policy, or risk management.

Students may receive different grades based on their individual reflections.

Academic Integrity

All submitted work must comply with the university’s academic integrity policies.

Students are responsible for:

- properly citing sources,
- ensuring originality of work,
- and accurately representing their contributions.

Grading Rubric

Group Presentation (10%)

Criteria	Marks
Coverage, accuracy, and depth	4
Class engagement and discussion facilitation	3
Quality of the materials (readable, coherent, appropriate visuals) Professionalism and overall quality of the presentation	2
Submission of presentation materials by the deadline	1

Group Written Report (5%)

Criteria	Marks
Technical analysis and accuracy	2
Policy, governance, and risk analysis	1
Research quality and references	1
Clarity, organization, and professionalism	1

Individual Contribution Reflection (5%)

Criteria	Marks
Clear explanation of contributions	2
Quality of reflection and insight	2
Professionalism and completeness	1

Case Study Topics

Group #	Case Study	Description
1 Policies and Frameworks	AI and Security Policies: OpenAI and Generative AI	Explore how OpenAI manages the security and ethical concerns of generative AI. 1. What security risks are associated with generative AI? 2. How should policies address the misuse of AI-generated content? 3. What ethical considerations should guide AI development? 4. How should organizations secure training datasets? 5. What lessons can be learned from OpenAI's approach?
2 Privacy vs. Security	Clearview AI's Facial Recognition	Debate the ethical and security implications of Clearview AI's technology. 1. What privacy risks does Clearview AI's technology pose? 2. How should policies balance innovation with privacy? 3. What ethical issues are raised by this technology? 4. How should governments regulate facial recognition systems? 5. What are best practices for securing sensitive data in such applications?

3 Business Continuity	Sony Pictures Hack (2014)	Analyze the impact of the Sony Pictures hack on business continuity and reputation. 1. How did the hack exploit weaknesses in Sony's systems? 2. What role did incident response policies play in their recovery? 3. How did the hack affect Sony's business operations? 4. What improvements should be made to their business continuity policies? 5. What lessons can other companies learn?
4 Zero Trust	Zero Trust Architecture: Google's BeyondCorp	Explore Google's transition to Zero Trust security with BeyondCorp. 1. What is Zero Trust, and how does it differ from traditional models? 2. What challenges did Google face during implementation? 3. How did this model improve security at Google? 4. What lessons can other organizations learn? 5. How does Zero Trust influence third-party risk management?
5 Social Engineering	Uber Breach (2022)	Investigate the 2022 Uber cybersecurity breach, where attackers used social engineering and MFA fatigue techniques to gain access to internal systems. Analyze the incident from the perspectives of identity and access management, employee security awareness, incident response, and organizational security policies. 1. How did the attackers use social engineering and MFA fatigue techniques to compromise Uber's systems? 2. What weaknesses in identity and access management practices contributed to the breach?

		- How could stronger authentication controls, monitoring, and employee security awareness training have reduced the likelihood or impact of the attack? - What operational, reputational, and security impacts did the breach have on Uber? - What lessons should organizations learn regarding Zero Trust, privileged access management, MFA implementation, and incident response preparedness?
6 Social Engineering	Twitter Hack (2020)	Investigate how social engineering led to the compromise of high-profile accounts. - What techniques did the attackers use? - How could Twitter have prevented such attacks? - What role does employee training play in reducing risks? - What technical solutions could mitigate social engineering threats? - What lessons can other companies learn from this incident?
7 Data Breach	Desjardins Group Data Breach (2019)	Investigate Desjardins Group data breach, and explore the role of internal security policies, employee monitoring, and incident response. This breach severely impacted customer trust and led to heightened regulatory scrutiny in Canada. - What specific failures in Desjardins' internal security policies allowed the insider threat to succeed? - How could improved access control and employee monitoring policies have prevented this breach? - What role did Desjardins' incident response plan play in managing the fallout, and how could it be improved? - How should organizations balance privacy and monitoring to prevent insider threats while maintaining trust among

		employees? 5. What regulatory requirements were relevant in addressing the breach?
8 Data Breach	Target Data Breach (2013)	Analyze how human error and insufficient policies contributed to the Target data breach. 1. How did the attackers exploit third-party vulnerabilities? 2. What role did human error play in the breach? 3. How effective was Target's response? 4. What employee training measures could have mitigated the risk? 5. What role should vendor risk management play in security policies?
9 Data Breach	Yahoo Password Leaks (2013–2017)	Investigate the Yahoo data breaches and password leaks that spanned several years, making them among the largest cybersecurity incidents in history. 1. How did attackers gain access to Yahoo's systems in the 2013 and 2014 breaches, and what vulnerabilities were exploited? 2. What authentication mechanisms and access control policies failed to prevent repeated compromises? 3. What types of sensitive data were exposed in each breach, and how many accounts were affected overall? 4. How did Yahoo respond to these breaches, and what legal, regulatory, and financial consequences followed? 5. What broader lessons can be drawn for access control management, incident response, and corporate accountability?

10 Data Breach	Facebook Data Exposure and Scraping Incident (2019)	Analyze the causes and consequences of Facebook's data exposure incident. 1. What specific vulnerabilities led to the breach? 2. How effective were Facebook's existing security measures? 3. How did Facebook respond to the breach? 4. Evaluate whether scraping constitutes a data breach under current legal and policy definitions. 5. What changes were implemented post-breach?
11 Information classification and asset management	Canadian Government's Leak of Student Loan Information (2013)	Describe Human Resources and Skills Development Canada (HRSDC) 2013 data leak of student loan borrowers. 1. What were the key factors that contributed to the loss of sensitive data by HRSDC? 2. What steps did HRSDC take to address the data breach, and how effective do you think these measures are in preventing future incidents? 3. Evaluate the new policies introduced. 4. What alternative policies could HRSDC have implemented to safeguard sensitive data more effectively? 5. How should HRSDC rebuild trust with affected individuals and the public?

12 Smart Devices and Privacy	Verkada Camera Breach (2021)	Investigate the 2021 Verkada security breach, where attackers gained access to thousands of internet-connected security cameras deployed in hospitals, schools, prisons, factories, and corporate offices. Analyze the incident from the perspectives of cloud security, surveillance systems, privacy, access control, and third-party risk management. 1. How did attackers gain access to Verkada's systems and connected surveillance cameras? 2. What weaknesses in access control, credential management, or cloud security contributed to the breach? 3. What privacy, ethical, and legal concerns arose from the compromise of internet-connected surveillance systems? 4. How should organizations evaluate and manage risks associated with cloud-managed smart devices and third-party vendors? 5. What lessons can organizations learn regarding zero trust, privileged access management, monitoring, and the secure deployment of smart surveillance technologies?
13 Accounts Management	Colonial Pipeline Attack (2021)	Investigate the ransomware attack on Colonial Pipeline and its implications for critical infrastructure. 1. What vulnerabilities allowed the attack to succeed? 2. How effective was Colonial Pipeline's incident response plan? 3. What was the impact of paying the ransom? 4. What lessons can be learned from their response? 5. How can critical infrastructure organizations better prepare for ransomware attacks?

14 Insider Threats	Tesla IP Theft	Summarize the legal cases that Tesla has brought against its employees related to insider threats and intellectual property theft. In your summary, address the following: 1. For each legal case, discuss the cause of action (e.g., trade secret theft, breach of contract, defamation), and the ruling or outcome where available. 2. What policies failed to prevent insider access? 3. How should organizations monitor employee activity without violating privacy? 4. How can access control policies mitigate insider risks? 5. What lessons can be applied across industries? Include at least Tesla v. Sterling Anderson (2017), Tesla v. Guangzhi Cao (2019), Tesla v. Alex Khatilov (2021), and Tesla v. Rivian
15 Privacy Violation	Cambridge Analytica Scandal (2018)	Examine the privacy violations and regulatory responses following the Cambridge Analytica scandal. 1. What privacy violations occurred, and how were they facilitated? 2. How did Facebook's policies contribute to these issues? 3. What ethical concerns are raised by monetizing user data? 4. What regulatory changes followed the scandal? 5. How can social media platforms rebuild trust with users?

16 Cloud Security	Cloud Security: AWS and Capital One Breach (2019)	Explore AWS's security practices and analyze a specific incident, such as the 2019 Capital One data breach involving AWS. 1. How does AWS's shared responsibility model influence security? 2. What vulnerabilities were exploited in the Capital One incident? 3. How effective are AWS's current security policies? 4. What role does encryption play in securing cloud data? 5. What improvements could enhance cloud security?
17 Incident Handling	Ukraine Power Grid Hack (2015)	Examine how attackers compromised industrial control systems (ICS) and operational technology (OT) during the Ukraine power grid attack. 1. How did attackers gain access to the power grid's systems? 2. What weaknesses in industrial control systems and operational technology contributed to the attack? 3. How can critical infrastructure security policies reduce risks to operational technology environments? 4. What international standards and frameworks exist for securing critical infrastructure and industrial control systems? 5. How should incident response and recovery plans be adapted to address attacks against critical infrastructure?
18 Operational Security	Equifax Data Breach (2017)	Explore the technical and policy failures that led to the Equifax data breach. 1. What vulnerabilities allowed the breach? 2. How effective were Equifax's security policies at the time? 3. How did the absence of controls recommended by different frameworks contribute to the breach? 4. How did Equifax handle communication with stakeholders? 5. What new policies or frameworks could prevent similar

		breaches in the future?
19 Incident Handling	PowerSchool Data Breach and Extortion Incident (2024–2025)	Investigate the PowerSchool cybersecurity breach and its implications for educational software and data security. 1. How did attackers infiltrate PowerSchool’s systems? 2. What security policies or technical controls failed to prevent the breach? 3. What data was exfiltrated, and who was affected? 4. Was this a ransomware attack? What role did extortion play? 5. What mitigation and response strategies were enacted?
20 Ransomware	Cybersecurity in Healthcare: WannaCry (2017)	Explore how the WannaCry ransomware affected healthcare systems. 1. What vulnerabilities allowed WannaCry to spread in healthcare systems? 2. How effective were existing security policies? 3. What challenges do legacy systems pose in cybersecurity? 4. How can policies improve resilience against ransomware? 5. What lessons can the healthcare sector learn from this attack?
21 Access Controls	Marriott Breach (2018)	Analyze the role of access control failures in the Marriott breach. 1. What specific access control failures contributed to the breach? 2. How could encryption and segmentation have mitigated the damage? 3. How effective were Marriott’s incident response measures? 4. What long-term changes did Marriott implement? 5. What lessons can the hospitality industry take from this breach?

22 Access Controls	23andMe Hack (2023)	Investigate the 23andMe cybersecurity breach and its implications for access control management in consumer platforms. 1. How did attackers infiltrate 23andMe's systems, and what role did credential stuffing and lack of MFA play in the breach? 2. What access control policies or technical safeguards failed to prevent unauthorized account access? 3. What types of sensitive data were compromised, and how does genetic data present unique risks compared to other personal information? 4. What monitoring or adaptive access control mechanisms could have detected or limited the attackers' large-scale data scraping? 5. What lessons should organizations handling sensitive personal data learn from this incident?
23 Supply Chain	Supply Chain Security: SolarWinds Attack (2020)	Investigate the SolarWinds supply chain attack and its global implications. 1. How did the attackers infiltrate SolarWinds' systems? 2. What security policies failed to prevent the attack? 3. How should organizations vet third-party vendors? 4. What role does monitoring play in detecting supply chain threats? 5. How can international collaboration mitigate such risks?

24 SDLC	Open-Source: XZ Backdoor (2024)	Investigate the XZ Utils backdoor incident (CVE-2024-3094) and its implications for open-source security. 1. How did attackers infiltrate the XZ project? 2. What vulnerabilities of the open-source model did this backdoor expose? 3. What security policies and practices failed? 4. How should organizations evaluate and monitor open-source dependencies? 5. How can the open-source ecosystem strengthen resilience against such risks?
25 SDLC	Bell Canada's Data Leaks (2014-2018)	Investigate customer data leaks at Bell, focusing on systems development mistakes and preventive measures. 1. What were the key systems development mistakes that allowed the leaks to happen? 2. How could secure coding practices have mitigated the risk of SQL injection vulnerabilities? 3. What policies should Bell have implemented to enforce regular security testing and vulnerability management? 4. How could the use of advanced detection tools and automated scanning have prevented this breach? 5. What lessons can other organizations learn from this incident to improve their systems development lifecycle (SDLC)?

26 Business Continuity and Operations	CrowdStrike Falcon Outage (2024)	Investigate the global IT outage caused by a faulty CrowdStrike Falcon update in 2024. Analyze the incident from the perspectives of operational security, change management, business continuity, and software deployment risk. 1. What technical issue caused the CrowdStrike outage, and why did it have such widespread impact? 2. What role did software testing, quality assurance, and change management play in the incident? 3. How did the outage demonstrate the risks of centralized security platforms and endpoint management systems? 4. How effective were affected organizations' business continuity and disaster recovery plans? 5. What lessons should organizations learn regarding operational resilience, software deployment, and dependency management?
27 Nation-State and Supply Chain Attacks	NotPetya Attack (2017)	Investigate the NotPetya malware attack and its global impact. Analyze the incident from the perspectives of supply chain security, nation-state cyber operations, incident response, and business continuity. 1. How did attackers use the Ukrainian accounting software supply chain to distribute NotPetya? 2. Why was NotPetya particularly destructive compared to traditional ransomware? 3. What security controls and organizational policies failed to contain the spread of the malware? 4. How did the attack impact global organizations operationally and financially? 5. What lessons can organizations learn regarding supply chain risk management, segmentation, patch management, and

		business continuity planning?
28 Identity and Access Management	Okta Support System Breach (2023)	Investigate the Okta support system breach and its implications for identity and access management, third-party trust, and customer account security. Analyze the incident from the perspectives of authentication systems, support process security, and identity provider risk. 1. How did attackers gain access to Okta's support systems, and what information was exposed? 2. What role did identity and access management practices play in the incident? 3. How did the breach demonstrate the risks associated with third-party identity providers and centralized authentication services? 4. What security controls or support procedures could have reduced the impact of the breach? 5. What lessons should organizations learn regarding session management, support system security, and customer trust?
29 AI and Content Moderation	Microsoft Tay Chatbot Failure (2016)	Investigate Microsoft's AI chatbot "Tay," which was released on Twitter and quickly manipulated into generating offensive content. 1. What design and moderation weaknesses allowed Tay to be manipulated so quickly? 2. What role did inadequate input validation and monitoring play in the incident? 3. How should organizations manage risks associated with publicly deployed AI systems? 4. What ethical and reputational challenges emerged from the incident?

		5. What policies, safeguards, or governance mechanisms should organizations implement before deploying AI systems publicly?
30 Insider Threats	Waymo v. Uber (2017)	Investigate the legal dispute between Waymo and Uber. Analyze the case from the perspectives of insider threats, intellectual property protection, access control, corporate governance, and ethical business conduct. 1. What events led to the Waymo v. Uber dispute, and what trade secrets were allegedly stolen? 2. What role did insider threats and employee access privileges play in the incident? 3. How could stronger access control, monitoring, and data loss prevention (DLP) mechanisms have reduced the risk of intellectual property theft? 4. What legal, ethical, and corporate governance issues emerged from the case? 5. What lessons should organizations learn regarding intellectual property protection, employee offboarding, third-party hiring practices, and secure handling of sensitive engineering data?